

SOFTWARE VERIFICATION AND VALIDATION- LAB

Task- 14



Bachelor of Science Software Engineering

Name/ Roll No:

Khadija Khalid/ Fall'23/BSSE/172

Submitted to:

Maam Javeria

LAHORE GARRISON UNIVERSITY

Session: 2023 – 2027

Final Compliance Dossier

1. Project Overview

This project focuses on **security validation and compliance documentation** for a demo web application. The objective of the validation process was to identify security vulnerabilities, assess associated risks, and organize all validation evidence into a structured compliance dossier for audit review.

The security assessment was performed using **OWASP ZAP (Zed Attack Proxy)**, an automated web application security testing tool. The scan aimed to detect vulnerabilities related to security misconfigurations, missing security headers, and information disclosure issues. The findings were documented and converted into a risk register, with recommended mitigation actions provided to improve the security posture of the application.

2. Summary of Security Validation (Week 13)

A security validation scan was performed on the demo web application using **OWASP ZAP**. The scan analysed the application's HTTP responses and security configurations to identify potential vulnerabilities.

The following security issues were identified during the scan:

- **Content Security Policy (CSP) Header Not Set**
- **Cross-Domain Misconfiguration**
- **Server Leaks Version Information via "Server" HTTP Response Header**
- **Strict-Transport-Security (HSTS) Header Not Set**
- **Timestamp Disclosure – Unix**
- **Modern Web Application (Informational)**
- **Re-examine Cache-control Directives**

The results indicate that the application lacks several important security headers and exposes unnecessary server information, which may increase the risk of exploitation by attackers.

All scan reports, screenshots, and validation logs were collected as supporting evidence.

3. Risk Register Table

<i>Risk ID</i>	<i>Risk Description</i>	<i>Source Evidence</i>	<i>Probability</i>	<i>Impact</i>	<i>Risk Level</i>	<i>Mitigation</i>
VR-01	Content Security Policy (CSP) Header Not Set	OWASP ZAP Scan Report	High	High	Critical	Implement Content-Security-Policy header to restrict trusted content sources.
VR-02	Cross-Domain Misconfiguration	OWASP ZAP Scan Report	Medium	High	High	Configure proper CORS policies to allow only trusted domains.
VR-03	Server Leaks Version Information via "Server" HTTP Response Header	OWASP ZAP Scan Report	Medium	Medium	Moderate	Hide or disable server version details in response headers.
VR-04	Strict-Transport-Security (HSTS) Header Not Set	OWASP ZAP Scan Report	High	High	Critical	Enable Strict-Transport-Security header to enforce HTTPS.
VR-05	Timestamp Disclosure – Unix	OWASP ZAP Scan Report	Low	Low	Low	Remove unnecessary timestamp exposure

						from responses.
VR-06	Modern Web Application (Informational)	OWASP ZAP Scan Report	Low	Low	Informational	No mitigation required.
VR-07	Re-examine Cache-control Directives	OWASP ZAP Scan Report	Medium	Medium	Moderate	Configure secure cache-control headers.

4. Evidence Summary

The following evidence was collected and organized as part of the compliance dossier:

- **OWASP ZAP security scan report**
- **Screenshots of identified vulnerabilities and alerts**
- **Vulnerability summary document**
- **Validation risk register spreadsheet**
- **Validation logs and scan outputs**
- **Folder structure documentation for compliance audit**

All evidence has been stored systematically to support security review and audit verification.

5. Mitigation Actions

Based on the identified vulnerabilities, the following corrective actions are recommended:

- Implement **Content Security Policy (CSP)** headers to reduce the risk of script injection attacks.
- Configure proper **Cross-Origin Resource Sharing (CORS)** settings to prevent unauthorized cross-domain access.
- Remove or hide **server version information** from HTTP response headers.
- Enable **HTTP Strict Transport Security (HSTS)** to enforce secure HTTPS connections.
- Eliminate unnecessary **timestamp disclosures** from server responses.
- Review and update **cache-control directives** to prevent sensitive data from being stored in browser caches.

- Perform **re-testing using OWASP ZAP** after applying security fixes to verify mitigation effectiveness.

6. Conclusion

The security validation process successfully identified multiple security weaknesses in the demo web application, primarily related to missing security headers, configuration issues, and information disclosure.

These vulnerabilities were documented, analyzed, and organized into a structured compliance dossier for audit review. Recommended mitigation actions have been provided to strengthen application security and improve compliance readiness.

This compliance dossier demonstrates a systematic approach to validation risk management and provides clear evidence of security assessment activities performed during the project.